AEC CYBERSECURITY — LEA.D8 · COHORT CYB-01 · FALL 2026

420-D04-AB — Conformity Assessment

Day 3 — Legal frameworks — part 2: standards and frameworks, data retention, mapping, documentation

Tuesday, November 3, 2026 · 18:30–22:00 (Eastern, EST) · online

From the Industry to the Classroom — Building the IT's Future, Today and Together !

Materials © 2026 Cyber.SoHo Educational Hub — education only, lab-only use, confidentiality, intellectual property, own work. Course work is not an audit of any real organization. https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html

OPENING

Tonight — one hour, six lessons

- 18:30–18:45 — Recall of Day 2 — the five texts that apply to Érable Cycles, breach duties, retention minimum vs maximum
- 18:45–18:55 — Lesson 1 — NIST CSF 2.0: Functions, Tiers, Profiles
- 18:55–19:05 — Lesson 2 — ISO/IEC 27001:2022 and Annex A
- 19:05–19:14 — Lesson 3 — CIS Controls v8.1, Controls vs Benchmarks, choosing for an SME
- 19:14–19:22 — Lesson 4 — Data retention: legal minimums and maximums, the schedule
- 19:22–19:30 — Lesson 5 — Mapping policies to requirements: the traceability matrix and crosswalks
- 19:45–19:53 — Lesson 6 — Documentation requirements: documents, records, evidence
- 19:53–22:00 — Lab 1 — Part B (guided 30–45 min, then individual work); due Sunday November 8, 23:59 EST

420-D04-AB Conformity Assessment · Day 3 · Cyber.SoHo Educational Hub — use subject to the Legal Notice, Terms of Use and Acceptable Use Policy v2.0

RECALL

Recall of Day 2 — laws and regulations (15 minutes)

- Hierarchy of obligations: laws and regulations (mandatory) → contractual standards (PCI DSS, binding through the merchant agreement) → voluntary frameworks (NIST CSF, ISO/IEC 27001, CIS Controls) → internal policies.
- The five texts that apply to Érable Cycles: PIPEDA (federal private-sector privacy law), Québec Law 25 (modernized Private Sector Act), GDPR (partly — only the data of customers located in the EU, Article 3(2)(a)), PCI DSS v4.0.1 (by contract; hosted payment page and P2PE terminals keep most systems out of the CDE) and CASL (the newsletter is a CEM).
- Breach duties: PIPEDA — report to the OPC and notify individuals when there is a real risk of significant harm, keep every breach record 24 months; Law 25 — notify the CAI and the persons when there is a risk of serious injury, keep the incident register at least 5 years; GDPR — notify the supervisory authority within 72 hours.

RECALL

Recall of Day 2 (2/2) — breach duties, CASL, Bill C-36

- CASL: consent (express or implied), sender identification and a working unsubscribe honoured within 10 business days; the sender must be able to prove consent.
- Retention — the bridge to tonight: the CRA sets a minimum (6 years for tax records); the privacy laws set a maximum (personal information only as long as necessary). Tonight's retention schedule respects both.
- Bill C-36 (Protecting Privacy and Consumer Data Act) — checked today, November 3, 2026: still at second reading in the House of Commons, no activity since first reading on June 15, 2026. It is proposed only; PIPEDA remains the law in force.

REMEMBER

CASL: consent (express or implied), sender identification and a working unsubscribe honoured within 10 business days; the sender must be able to prove consent.

Where it is used: Érable Cycles inc. — the case audited in every lab

1

LESSON 1

Lesson 1 — NIST CSF 2.0 in one slide

- Published February 26, 2024 (NIST CSWP 29) — voluntary, free, for any organization
- Describes outcomes, not settings and not products
- Three components: Core · Tiers · Organizational Profiles

REMEMBER

Published February 26, 2024 (NIST CSWP 29) — voluntary, free, for any organization

Where it is used: Lab 1 Part B.1 · Project Section 5

LESSON 1

1 The Core — six Functions

- Govern (GV) — new: strategy, policy, roles, supply chain
- Identify (ID) — assets, risks, improvements
- Protect (PR) — access, awareness, data, platforms, resilience
- Detect (DE) — monitoring, adverse-event analysis
- Respond (RS) — incident management, communication
- Recover (RC) — restoration, recovery communication



1

LESSON 1

Core structure — 6 / 22 / 106

- Function → Category → Subcategory
- 22 Categories, 106 Subcategories
- Identifier = Function.Category-Number, e.g. GV.PO-01
- A Subcategory is one specific, testable outcome

REMEMBER

Function → Category → Subcategory

Where it is used: Lab 1 Part B.1 · Project Section 5

1

LESSON 1

Tiers — governance rigor, not maturity

- Tier 1 Partial — ad hoc, reactive
- Tier 2 Risk Informed — approved practices, no organization-wide policy
- Tier 3 Repeatable — formal policy, regular updates
- Tier 4 Adaptive — continuous improvement, predictive indicators
- Érable Cycles: Tier 2 moving to Tier 3 is realistic

REMEMBER

Tier 1 Partial — ad hoc, reactive

Where it is used: Lab 1 Part B.1 · Project Section 5

1

LESSON 1

Organizational Profiles

- Current Profile — outcomes achieved today (evidence)
- Target Profile — outcomes required (laws, PCI DSS, risk appetite)
- Gap = target − current → ranked action plan
- A Profile = a small conformity assessment
- Community Profiles · Quick-Start Guides (NIST SP 1300 for small business)

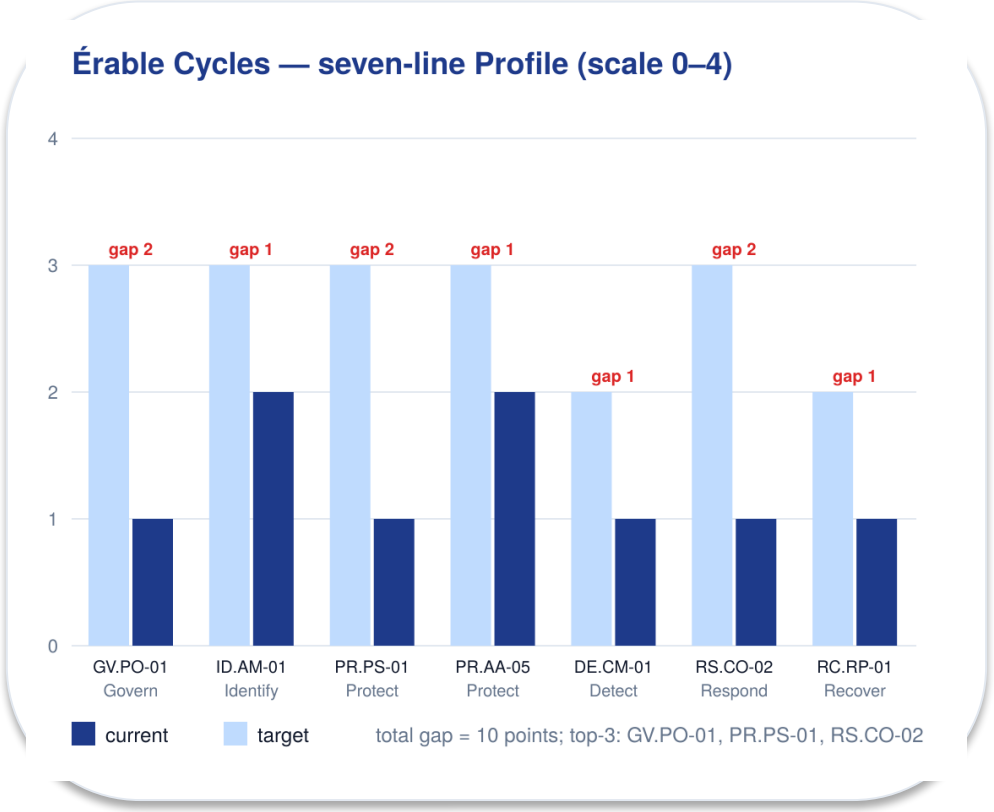
REMEMBER

Current Profile — outcomes achieved today (evidence)

Where it is used: Lab 1 Part B.1 · Project Section 5

Example — a seven-line Profile for Érable Cycles

- Seven Subcategories, one per Function (+1 Protect)
- Scale 0–4 chosen by the team; current and target scored from evidence
- Script computes the gaps and ranks them
- Top-3 gaps → first checks of the Lab 2 plan



1

LESSON 1

What the CSF gives — and does not give

- Gives: vocabulary, structure, free mappings, year-over-year progress
- Does not give: settings, certification, legal force
- Lab 1 default pair: CIS Controls v8.1 IG1 + CSF 2.0 Profile

REMEMBER

Gives: vocabulary, structure, free mappings, year-over-year progress

Where it is used: Lab 1 Part B.1 · Project Section 5

2

LESSON 2

Lesson 2 — ISO/IEC 27001:2022 in one slide

- Requirements of an ISMS — certifiable
- Third edition October 25, 2022; Amendment 1 (2024); 2013 transition ended October 31, 2025
- Certificate: accredited body (SCC-accredited in Canada), 3 years + annual surveillance
- Licensed text: cite numbers, never copy (Legal Notice 7.5)

REMEMBER

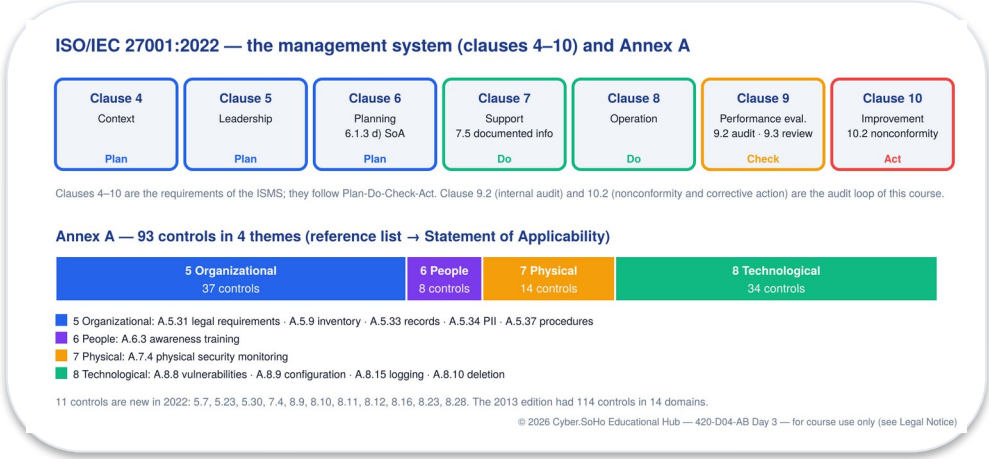
Requirements of an ISMS — certifiable

Where it is used: Lab 1 alternative · Lab 2 checklist · Lab 3

LESSON 2

2 Clauses 4–10 follow Plan-Do-Check-Act

- 4 Context — scope, interested parties, requirements
- 5 Leadership — policy, roles
- 6 Planning — risk assessment/treatment, 6.1.3 d) SoA
- 7 Support — 7.5 documented information
- 8 Operation
- 9 Performance evaluation — 9.1, 9.2 internal audit, 9.3 management review
- 10 Improvement — 10.2 nonconformity and corrective action



2

LESSON 2

Annex A — 93 controls, 4 themes

- 5 Organizational — 37
- 6 People — 8
- 7 Physical — 14
- 8 Technological — 34
- 11 new controls in 2022 (5.7, 5.23, 5.30, 7.4, 8.9, 8.10, 8.11, 8.12, 8.16, 8.23, 8.28)

REMEMBER

5 Organizational — 37

Where it is used: Lab 1 alternative · Lab 2 checklist · Lab 3

420-D04-AB Conformity Assessment · Day 3 · Cyber.SoHo Educational Hub — use subject to the Legal Notice, Terms of Use and Acceptable Use Policy v2.0

2

LESSON 2

The Statement of Applicability

- All 93 controls: applicable? justification · implemented?
- Required by clause 6.1.3 d)
- First document an ISO auditor asks for
- Applicable + not implemented = candidate nonconformity

REMEMBER

All 93 controls: applicable? justification · implemented?

Where it is used: Lab 1 alternative · Lab 2 checklist · Lab 3

2

LESSON 2

Controls you will meet again

- A.5.31 Legal, statutory, regulatory, contractual requirements — Lab 1
- A.5.34 Privacy and protection of PII
- A.5.9 Inventory · A.5.12 Classification — Lab 2
- A.5.33 Protection of records — retention
- A.5.37 Documented operating procedures — your CPM
- A.8.8, A.8.9, A.8.15, A.5.15, A.5.18 — Lab 3

REMEMBER

A.5.31 Legal, statutory, regulatory, contractual requirements — Lab 1

Where it is used: Lab 1 alternative · Lab 2 checklist · Lab 3

2

LESSON 2

Example — SoA extract for Érable Cycles

- 12 controls · theme · applicable (Y/N) · justification · implemented (Y/N)
- Bash + awk: table, counts per theme, gap list
- A.8.28 Secure coding not applicable (packaged web store maintained by the MSP)
- Applicable-but-missing controls → Lab 3 tests

REMEMBER

12 controls · theme · applicable (Y/N) · justification · implemented (Y/N)

Where it is used: Lab 1 alternative · Lab 2 checklist · Lab 3

2

LESSON 2

When does an SME choose ISO/IEC 27001?

- A customer, partner or tender requires the certificate
- Markets where the certificate is expected
- Cost: 12–18 months, consultants, certification fees, annual surveillance
- Érable Cycles: not today → documented alternative in Lab 1

REMEMBER

A customer, partner or tender requires the certificate

Where it is used: Lab 1 alternative · Lab 2 checklist · Lab 3

3

LESSON 3

Lesson 3 — CIS Controls v8.1 in one slide

- Prioritized safeguards from the Center for Internet Security — free
- 18 Controls · 153 Safeguards · 3 Implementation Groups
- v8.1 (June 2024): Governance function, CSF 2.0 alignment, no Safeguard changed
- A Safeguard says what to do (4.1 secure configuration process, 5.2 unique passwords)

REMEMBER

Prioritized safeguards from the Center for Internet Security — free

Where it is used: Lab 1 Part B.1 · Lab 2 checklist · Lab 3 tools

3

LESSON 3

The 18 Controls (IG1 Safeguards in brackets)

- 1 Enterprise assets (2) · 2 Software assets (3) · 3 Data protection (6)
- 4 Secure configuration (7) · 5 Accounts (4) · 6 Access control (5)
- 7 Vulnerabilities (4) · 8 Audit logs (3) · 9 Email & browser (2)
- 10 Malware (3) · 11 Data recovery (4) · 12 Network infrastructure (1)
- 13 Network monitoring (0) · 14 Awareness (8) · 15 Service providers (1)
- 16 Application security (0) · 17 Incident response (3) · 18 Penetration testing (0)

REMEMBER

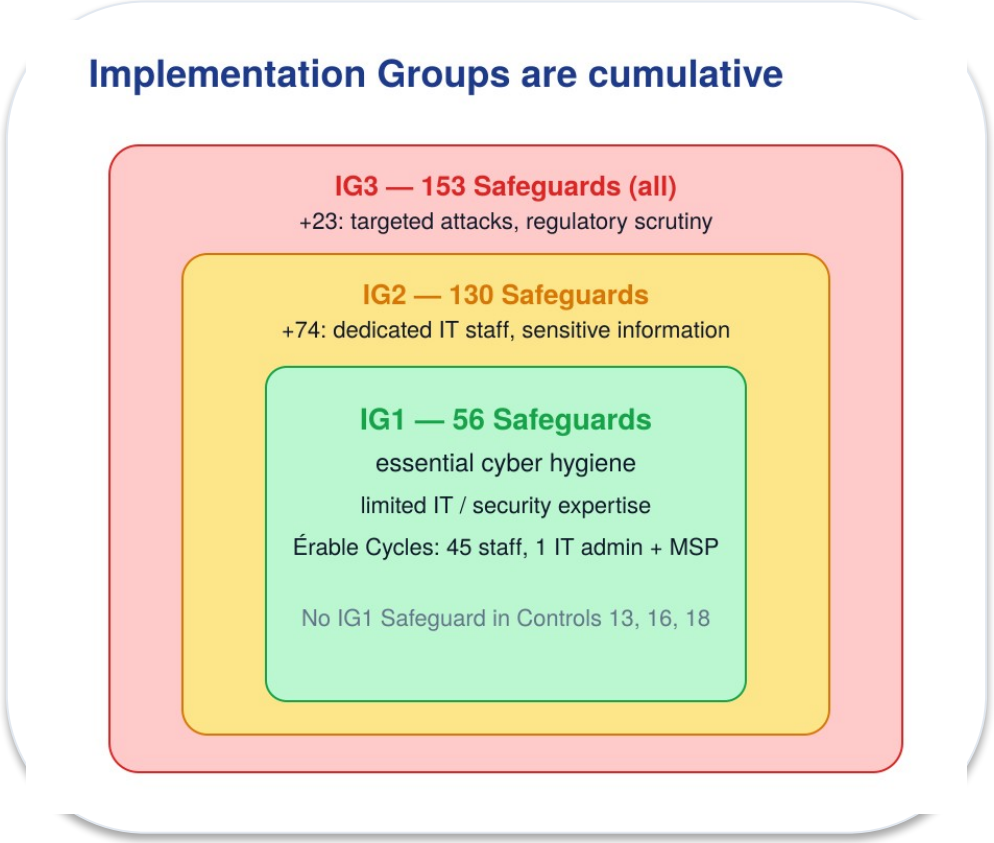
1 Enterprise assets (2) · 2 Software assets (3) · 3 Data protection (6)

Where it is used: Lab 1 Part B.1 · Lab 2 checklist · Lab 3 tools

LESSON 3

Implementation Groups — cumulative

- IG1 — 56 Safeguards — essential cyber hygiene (SME)
- IG2 — +74 = 130 — dedicated IT staff, sensitive data
- IG3 — +23 = 153 — targeted attacks, regulatory scrutiny
- No IG1 Safeguard in Controls 13, 16, 18
- Érable Cycles: 45 employees, 1 IT admin + MSP → IG1



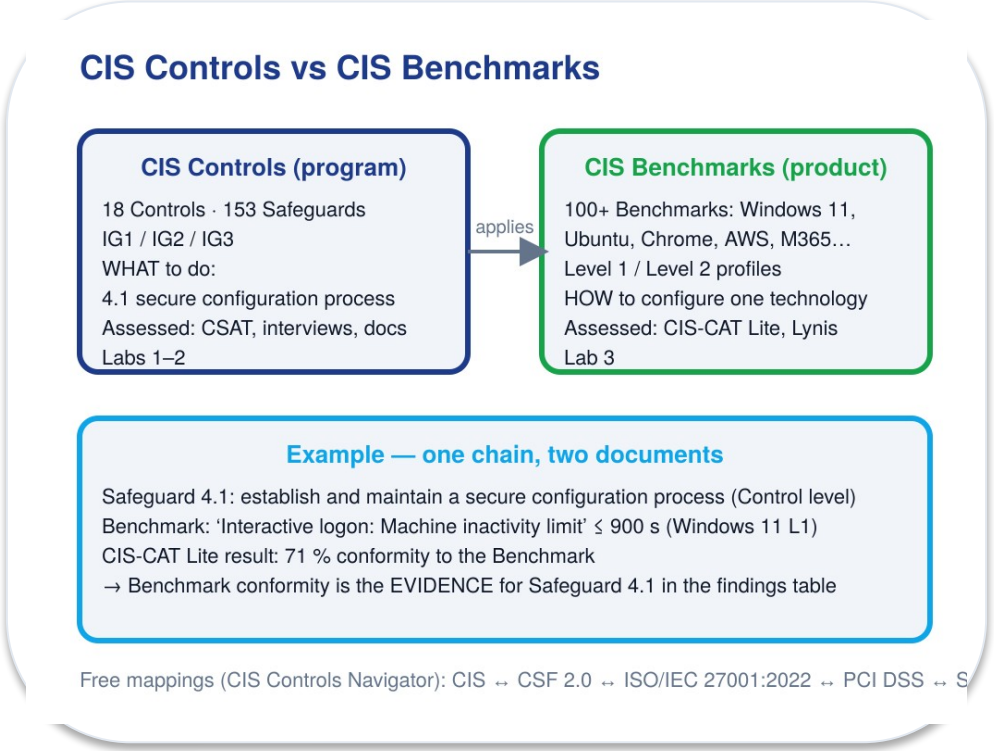
420-D04-AB Conformity Assessment · Day 3 · Cyber.SoHo Educational Hub — use subject to the Legal Notice, Terms of Use and Acceptable Use Policy v2.0

LESSON 3

3

CIS Controls vs CIS Benchmarks

- Controls = program: what to do · Safeguards · IG1–3
- Benchmarks = product: how to configure one technology · Level 1 / Level 2
- Safeguard 4.1 asks for a process; the Benchmark is the standard it applies
- CIS-CAT Lite measures Benchmark conformity → evidence for Control 4
- Lab 1–2: Controls · Lab 3: Benchmarks



3

LESSON 3

Mappings and tools

- Mappings: CIS ↔ CSF 2.0 ↔ ISO/IEC 27001:2022 ↔ PCI DSS ↔ SP 800-53
- CIS Controls Navigator (online crosswalk)
- CIS CSAT — self-assessment of Safeguards
- CIS RAM — risk method (mention only; we use a 3×3 matrix)

REMEMBER

Mappings: CIS ↔ CSF 2.0 ↔ ISO/IEC 27001:2022 ↔ PCI DSS ↔ SP 800-53

Where it is used: Lab 1 Part B.1 · Lab 2 checklist · Lab 3 tools

3

LESSON 3

Example — IG1 coverage in 14 Safeguards

- Implemented 1 · Partial 0.5 · Missing 0
- Coverage per Control and overall
- Evidence source: Program (documents) vs Benchmark (VM tools)
- Benchmark rows → Lab 3 · Program rows → 5-question policy check

REMEMBER

Implemented 1 · Partial 0.5 · Missing 0

Where it is used: Lab 1 Part B.1 · Lab 2 checklist · Lab 3 tools

LESSON 3

Choosing for an SME — three sentences

- PCI DSS is not a choice when cards are accepted (scope is the decision)
- Start with CIS Controls v8.1 IG1 — concrete, free, prioritized
- Add a CSF 2.0 Profile — structure and reporting
- ISO/IEC 27001 only when a certificate is required

REMEMBER

PCI DSS is not a choice when cards are accepted (scope is the decision)

Where it is used: Lab 1 Part B.1 · Lab 2 checklist · Lab 3 tools

4

LESSON 4

Lesson 4 — Retention in one slide

- Legal minimum: keep at least — tax 6 years, PCI DSS logs 12 months, breach register 24 months, incident register 5 years
- Legal maximum: keep no longer than necessary — PIPEDA 4.5, Law 25 s. 23, GDPR 5(1)(e)
- Minimum wins while it lasts; then the maximum applies
- Policy states the rules; the schedule applies them per record type

REMEMBER

Legal minimum: keep at least — tax 6 years, PCI DSS logs 12 months, breach register 24 months, incident register 5 years

Where it is used: Lab 1 Part B.3 · Lab 3 log settings

4

LESSON 4

Sources — minimums

- CRA / Revenu Québec — 6 years from the end of the last tax year
- PCI DSS 10.5.1 — logs ≥ 12 months, last 3 months immediately available
- PIPEDA breach regulations s. 6 — breach records 24 months
- Law 25 incident regulation — register entries 5 years
- CASL s. 13 — be able to prove consent (3-year limitation)

REMEMBER

CRA / Revenu Québec — 6 years from the end of the last tax year

Where it is used: Lab 1 Part B.3 · Lab 3 log settings

4

LESSON 4

Sources — maximums

- PIPEDA 4.5 — only as long as necessary; 4.5.2 min/max guidelines; 4.5.3 destroy, erase or anonymize
- Law 25 s. 23 — destroy or anonymize once the purpose is achieved (2024 anonymization regulation)
- GDPR 5(1)(e) — storage limitation; Art. 13 inform; Art. 30 ROPA time limits
- PCI DSS 3.2.1 — account data kept to a minimum; quarterly verification
- CCTV — regulator guidance: short, destroy unless incident

REMEMBER

PIPEDA 4.5 — only as long as necessary; 4.5.2 min/max guidelines; 4.5.3 destroy, erase or anonymize

Where it is used: Lab 1 Part B.3 · Lab 3 log settings

LESSON 4

The seven columns of a retention schedule

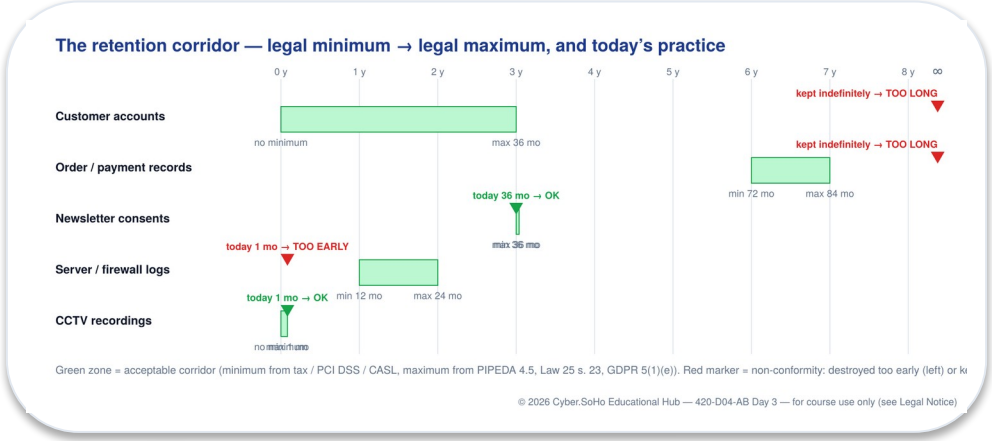
- 1 Record type (PI? card data?)
- 2 Legal basis — minimum and maximum
- 3 Retention period
- 4 Trigger event
- 5 Disposal method
- 6 Owner (business role)
- 7 Exceptions — legal hold

4

LESSON 4

Example — five rows checked against the law

- Accounts never deleted → TOO LONG
- Orders kept forever → TOO LONG after 6 years
- Consents: life of consent + 3 years → OK
- Firewall logs rotated after 30 days → TOO EARLY (10.5.1)
- CCTV overwritten after 30 days → OK



4

LESSON 4

Retention is tested on documents and on systems

- Policy and schedule (Lab 1)
- logrotate / journald on Ubuntu, event-log sizes on Windows (Lab 3)
- Backup NAS retention; Microsoft 365 retention policies (demo)
- Policy says 12 months, server keeps 2 weeks = non-conformity with evidence on both sides

REMEMBER

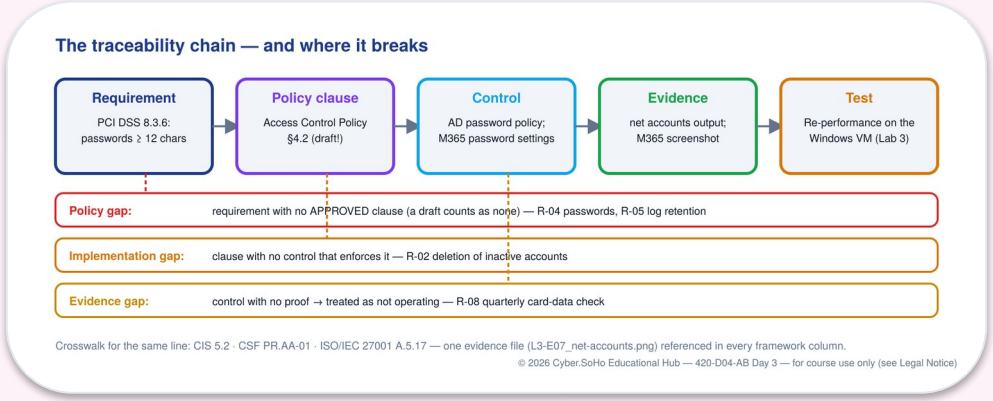
Policy and schedule (Lab 1)

Where it is used: Lab 1 Part B.3 · Lab 3 log settings

LESSON 5

Lesson 5 — Mapping in one slide

- Requirement → policy clause → control → evidence → test
- The traceability matrix keeps the five on one line per requirement
- Forward: requirement to proof · Backward: proof to requirement
- Project Section 6 = the matrix with results



5

LESSON 5

The eight columns

- Req ID · Source (article) · Requirement (plain words)
- Policy & clause · Control · Evidence to collect
- Test (Lab 3 method or tool) · Framework references (crosswalk)
- Example R-04: PCI DSS 8.3.6 → Access Control Policy §4.2 (draft) → AD password policy → net accounts output

REMEMBER

Req ID · Source (article) · Requirement (plain words)

Where it is used: Lab 1 Part B.2 · Lab 3 evidence · Project Section 6

LESSON 5

5

The three gap types

- Policy gap — requirement with no approved clause (a draft counts as none)
- Implementation gap — clause with no control
- Evidence gap — control with no proof → treated as not operating
- Ask: untested backups = which gap?

REMEMBER

Policy gap — requirement with no approved clause (a draft counts as none)

Where it is used: Lab 1 Part B.2 · Lab 3 evidence · Project Section 6

5

LESSON 5

Crosswalks — test once, satisfy many

- CIS Controls v8.1 mappings + Controls Navigator
- NIST OLIR / CPRT Informative References
- ISO/IEC 27002:2022 attributes (cybersecurity concepts = CSF Functions)
- Password ≥ 12: PCI DSS 8.3.6 · CIS 5.2 · PR.AA-01 · A.5.17 — one evidence file
- Name evidence once: L3-E07_net-accounts.png

REMEMBER

CIS Controls v8.1 mappings + Controls Navigator

Where it is used: Lab 1 Part B.2 · Lab 3 evidence · Project Section 6

LESSON 5

5

Example — eight requirements, three policies

- R-04 passwords: draft policy → policy gap
- R-05 log retention: no clause → policy gap
- R-02 deletion of inactive accounts: no job → implementation gap
- R-08 no card data stored: no quarterly record → evidence gap
- 4 supported / 8 → the four gaps are draft non-conformities

REMEMBER

R-04 passwords: draft policy → policy gap

Where it is used: Lab 1 Part B.2 · Lab 3 evidence · Project Section 6

5

LESSON 5

Compliance Manager — the automated matrix (demo)

- Microsoft Purview, in Microsoft 365 Business Premium
- Assessment templates: ISO/IEC 27001, NIST CSF, PCI DSS, GDPR, PIPEDA, Québec privacy law…
- Improvement actions · compliance score
- One action and its evidence shared across assessments
- Intune compliance policies / MECM baselines at device level — demo only

REMEMBER

Microsoft Purview, in Microsoft 365 Business Premium

Where it is used: Lab 1 Part B.2 · Lab 3 evidence · Project Section 6

420-D04-AB Conformity Assessment · Day 3 · Cyber.SoHo Educational Hub — use subject to the Legal Notice, Terms of Use and Acceptable Use Policy v2.0

LESSON 6

Lesson 6 — Documentation in one slide

- Documented information (ISO/IEC 27001 7.5) = documents + records
- Documents state rules, are maintained · Records prove activity, are retained
- “If it isn’t documented, it didn’t happen” = the definition of audit evidence
- Evidence: sufficient, reliable, relevant (ISO 19011)

REMEMBER

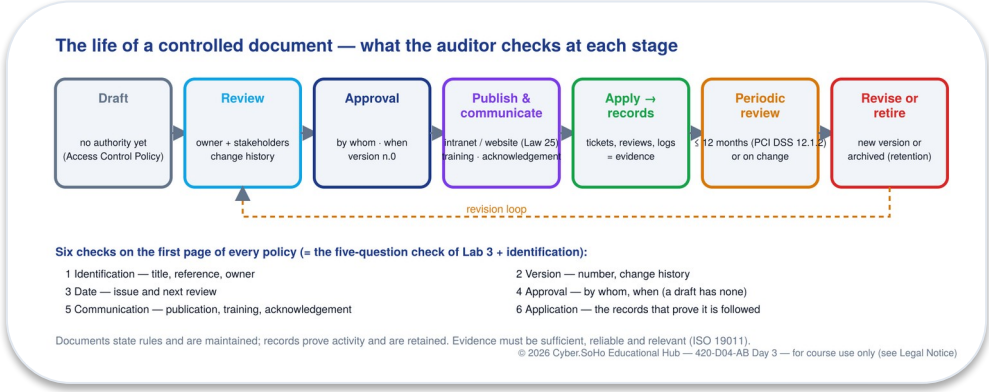
Documented information (ISO/IEC 27001 7.5) = documents + records

Where it is used: Lab 3 policy check · your CPM

LESSON 6

Document control — six checks on the first page

- Identification — title, reference, owner
- Version — number, change history
- Date — issue and next review (PCI DSS 12.1.2: ≤ 12 months)
- Approval — by whom, when; a draft has no authority
- Communication — publication, training, acknowledgement; Law 25 s. 3.2: published on the website
- Application — the records



6

LESSON 6

Records the law requires

- PIPEDA — breach records (24 months), consents, openness
- Law 25 — published policies, person in charge, PIA reports, incident register (5 years)
- GDPR — ROPA (Art. 30), breach documentation (Art. 33(5)), DPIA (Art. 35)
- PCI DSS — annual policy review, training, quarterly retention checks, log reviews, SAQ
- CASL — proof of consent, unsubscribe log

REMEMBER

PIPEDA — breach records (24 months), consents, openness

Where it is used: Lab 3 policy check · your CPM

6

LESSON 6

Example — the document register through the six checks

- 9 lines: 6 case-file policies/procedures + the MSP backup procedure + 2 records
- Checks: draft · no approval date · review overdue · not communicated · acknowledgement < 90 %
- Findings: Access Control Policy (draft), Patch Management Procedure (overdue), Acceptable Use Policy (61 %)
- Readiness = clean documents / total

REMEMBER

9 lines: 6 case-file policies/procedures + the MSP backup procedure + 2 records

Where it is used: Lab 3 policy check · your CPM

6

LESSON 6

Evidence rules of this course — and the CPM

- Unique evidence names: L3-E07_net-accounts.png — once in the evidence index
- Hostname and date visible; personal information masked (Legal Notice 18.2)
- “Not tested — reason: …” is acceptable; invented results fail
- The CPM = documented operating procedures (A.5.37): 7-line skeleton
- Chapter 1 this week: register, matrix, retention schedule

REMEMBER

Unique evidence names: L3-E07_net-accounts.png — once in the evidence index

Where it is used: Lab 3 policy check · your CPM

LAB 1

Lab 1 — Identify applicable laws, regulations and frameworks (10 %) — summary only

- Change announced tonight: the course now has three graded labs at 10 % each (plus the ungraded Lab 0) instead of five labs at 6 %. The total weight of the labs is unchanged (30 %). Lab 1 is due Sunday, November 8, 2026, 23:59 (Eastern — EST) in the Omnivox LÉA DropBox.
- Part A — done on Day 2: Applicability Register for PIPEDA, Law 25, GDPR, PCI DSS v4.0.1 and CASL: applies? (Yes / Partly / No) with a …
- Part B.1 — choose two frameworks (Lessons 1–3): Default: CIS Controls v8.1 IG1 + a NIST CSF 2.0 Organizational Profile; alternative: ISO/IEC 27001:2022 Annex …
- Part B.2 — mini traceability matrix (Lesson 5): 8 requirements taken from the register → the 3 given policies (Privacy Policy, Email Marketing Procedure, Paym…

LAB 1

Lab 1 — Part B tonight (2/2)

- Part B.3 — one-page retention schedule (Lesson 4): 5 record types: customer accounts, order / payment records, newsletter consents, server / firewall logs, CCTV — each with its legal basis (minimum and maximum), retention period, trigger, disposal method and owner. The Lesson 4 example produces the exact table.
- Output: One Lab 1 document (3–4 pages, PDF) = Part A + Part B, file name LastName_FirstName_420-D04-AB_Lab1.pdf, plus the filled template workbook. It becomes Project Section 3 — Legal & regulatory requirements and CPM Chapter 1 — How to identify applicable requirements.
- Rubric (10): register 4 · frameworks 1 · matrix 2.5 · retention schedule 1.5 · clarity 1

420-D04-AB Conformity Assessment · Day 3 · Cyber.SoHo Educational Hub — use subject to the Legal Notice, Terms of Use and Acceptable Use Policy v2.0

LAB 1

New lab schedule — 3 labs × 10 % (+ Lab 0)

- Lab 0 — Environment checklist — ungraded, required — Day 1 (Oct 27) — due before Day 7 → Tue Nov 10, 23:59
- Lab 1 — Applicable laws, regulations & frameworks — 10 % — Days 2–3 (Oct 28, Nov 3) — due Sun Nov 8, 23:59
- Lab 2 — Asset inventory & assessment plan — 10 % — Days 4–6 (Nov 4, 7, 10) — due Sun Nov 15, 23:59
- Lab 3 — Configuration audit & controls verification — 10 % — Days 7–10 (Nov 11, 14, 17, 18) — due Fri Nov 20, 23:59
- Project — Conformity Assessment Report — 15 % — Days 10–11 (Nov 18, 21) — due Tue Nov 24, 23:59
- Course Procedure Manual — 10 % — Day 1 → Day 11 — due Tue Nov 24, 23:59

REMEMBER

Lab 0 — Environment checklist — ungraded, required — Day 1 (Oct 27) — due before Day 7 → Tue Nov 10, 23:59

Where it is used: Érable Cycles inc. — the case audited in every lab

CLOSING

Recall points for Day 4

- The six CSF 2.0 Functions and what a Current / Target Profile is.
- ISO/IEC 27001:2022: clauses 4–10, Annex A = 93 controls in 4 themes, the Statement of Applicability, A.5.31.
- CIS Controls v8.1: 18 Controls, 153 Safeguards, IG1 = 56; Controls (program) vs Benchmarks (configuration).
- Retention: legal minimum (CRA 6 years) vs legal maximum (as long as necessary); PCI DSS 3.2.1 and 10.5.1.
- The traceability matrix: requirement → policy clause → control → evidence; the three gap types.
- Documents vs records; the 5-question policy check; “if it isn’t documented, it didn’t happen”.

REMEMBER

The six CSF 2.0 Functions and what a Current / Target Profile is.

Where it is used: Érable Cycles inc. — the case audited in every lab

CLOSING

Official links (selection)

- NIST Cybersecurity Framework 2.0 — official page
- ISO/IEC 27001:2022 — Information security management systems — Requirements
- CIS Critical Security Controls v8.1
- CIS Controls — Implementation Groups (IG1, IG2, IG3)
- PIPEDA — consolidated text (Justice Laws Website)
- Québec Act respecting the protection of personal information in the private sector (P-39.1)
- GDPR — Regulation (EU) 2016/679 (EUR-Lex)
- PCI Security Standards Council — Document Library
- CRA — Keeping records: how long to keep them
- CRTC — Canada’s Anti-Spam Legislation

CLOSING

Legal Notice, Terms of Use and Acceptable Use Policy

- Education only — not an audit — Section 3 and section 7.5 of the Legal Notice: the work you do on Érable Cycles is course work. It is not an audit, an a…
- Case file only, never real documents — Section 7.5 and Annex E: do not use an employer's, a client's or a family business's real policies, contracts, evidence …
- Licensed standards are not copied — Section 4.6 and section 7.5: ISO/IEC 27001, ISO/IEC 27002 and PCI DSS are licensed texts. The lecture quotes control tit…
- Intellectual property — Section 4: the lecture, templates, scripts and figures are Cyber.SoHo materials licensed for your personal study — no re…
- Academic integrity — Section 18: the Lab 1 document is your own work, follows the College's rules on collaboration and AI tools, and contains…
- https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html